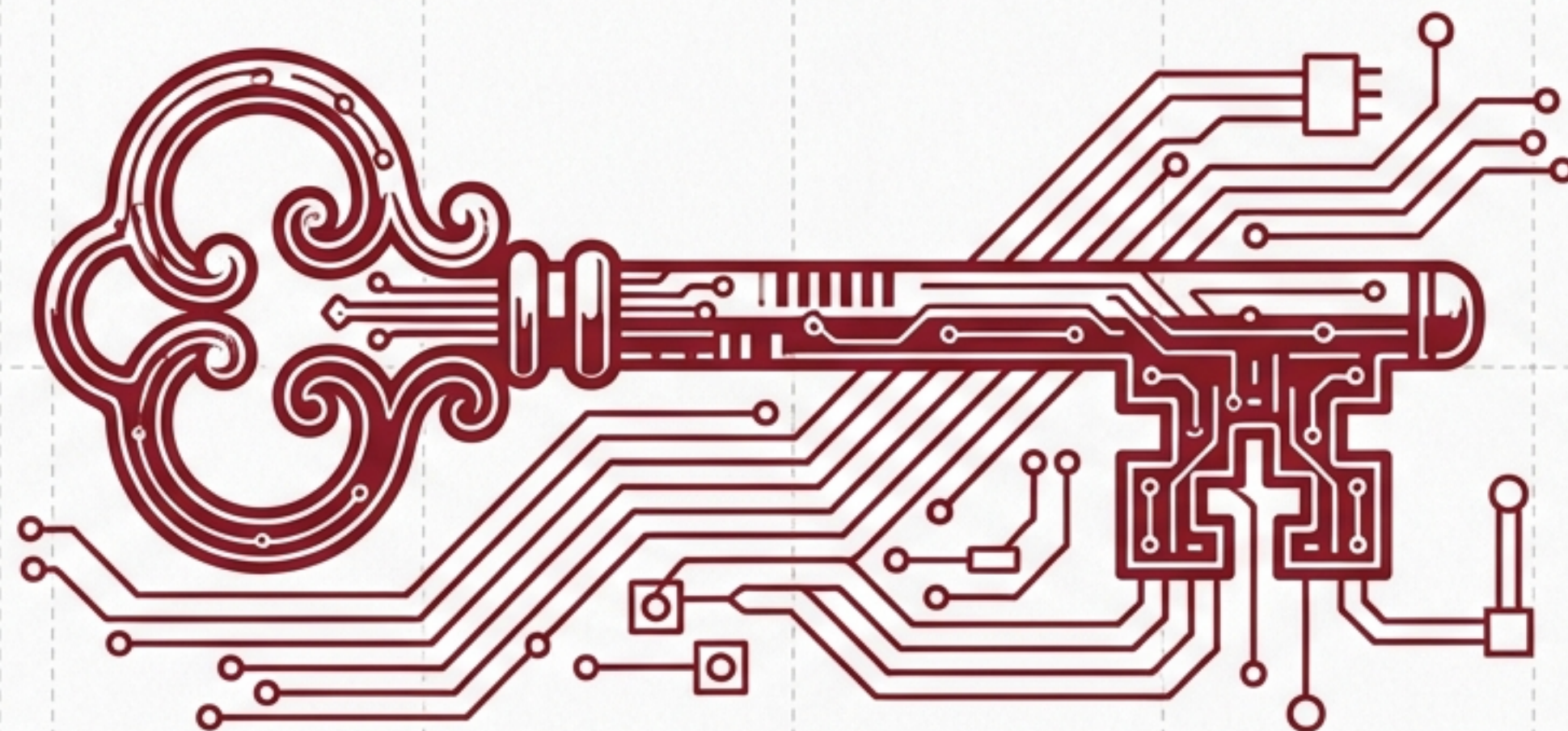


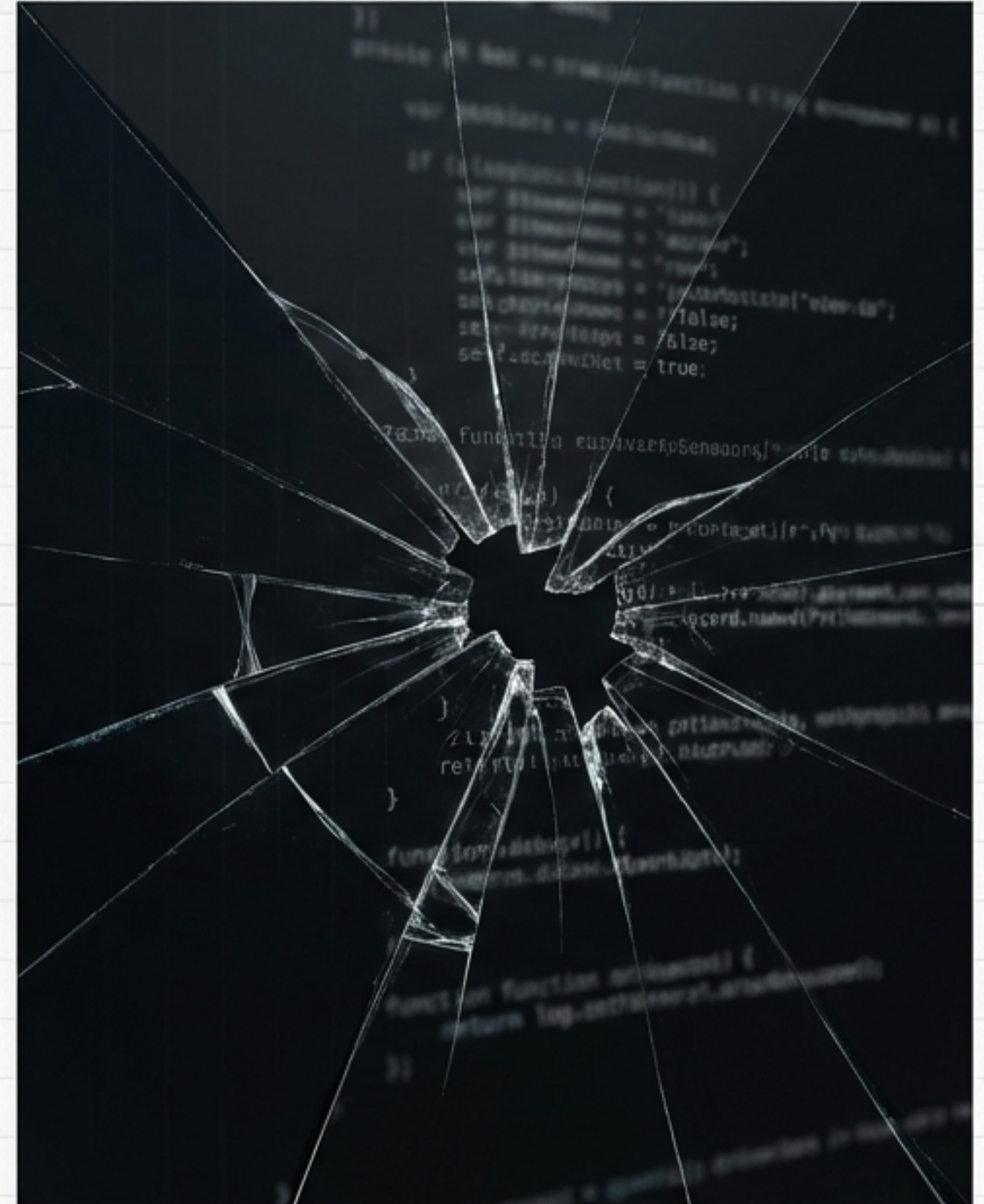
Más Allá del 0-Day



Elevación de privilegios en Windows mediante el robo de contraseñas, sesiones o hashes.

La escalada de privilegios no siempre es lo que parece.

En muchas intrusiones, el acceso total no proviene de un 'mega 0-day'. Nace de algo mucho más simple y común: credenciales, sesiones o hashes mal protegidos.



El Manual del Atacante: Un Plan de Juego en 5 Jugadas.

Para defender un sistema, primero debemos pensar como quien lo ataca. Analizaremos las tácticas más comunes que un intruso utiliza para escalar privilegios, moviéndose desde los errores más obvios hasta el núcleo del sistema.



1. Archivos de Texto



2. Registro de Windows



3. Credenciales del Navegador



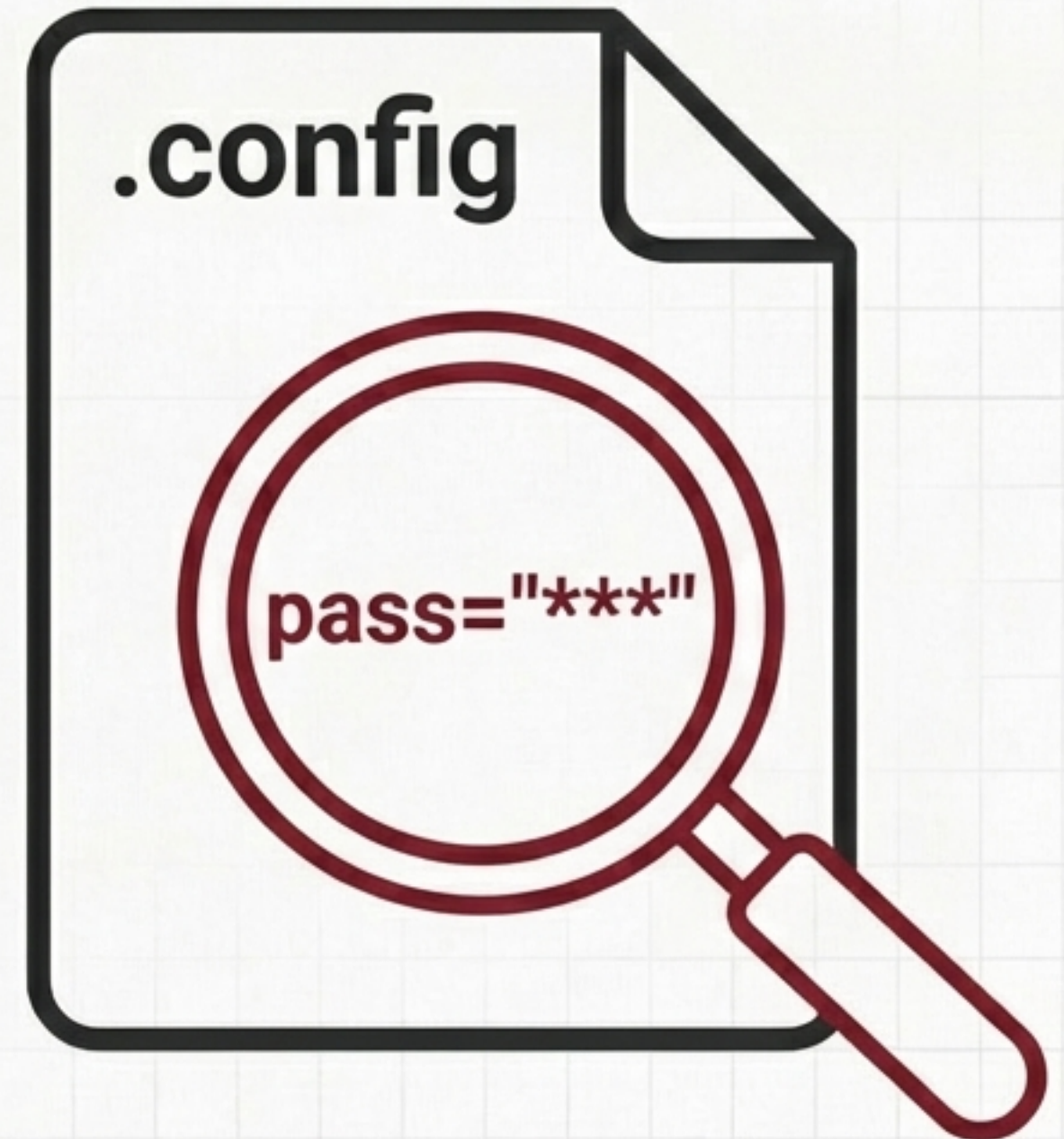
4. Base de Datos SAM



5. Escalada de Privilegios

Jugada 1 **La Búsqueda de Tesoros en Texto Plano.**

El primer y más simple objetivo. Muchos sistemas y aplicaciones aún guardan credenciales críticas en ficheros de configuración o scripts, ofreciendo la ruta de menor resistencia para un atacante.



Localizando Ficheros Sospechosos con PowerShell.

Un simple comando puede escanear recursivamente todo el sistema en busca de ficheros, como los de configuración (`.config`), que contengan la palabra 'password'.

```
Get-ChildItem -Recurse -ErrorAction SilentlyContinue | `
    Select-String "password" -List | `
    Select Path | `
    Where-Object { $_.Path -like "*.config" }
```


Jugada 2

Secretos Olvidados en el Registro del Sistema.

La siguiente parada para un atacante es el Registro de Windows. Configuraciones antiguas o descuidadas pueden dejar credenciales de autologin o detalles de sesiones remotas almacenados en ubicaciones predecibles.



Puntos de Fuga Comunes en el Registro.

Credenciales de Winlogon

En sistemas antiguos, Winlogon puede almacenar el usuario y la contraseña por defecto.

```
Get-ItemProperty  
"HKLM:\SOFTWARE\Microsoft\Windows  
NT\CurrentVersion\Winlogon"
```

Sesiones de Servicios Remotos

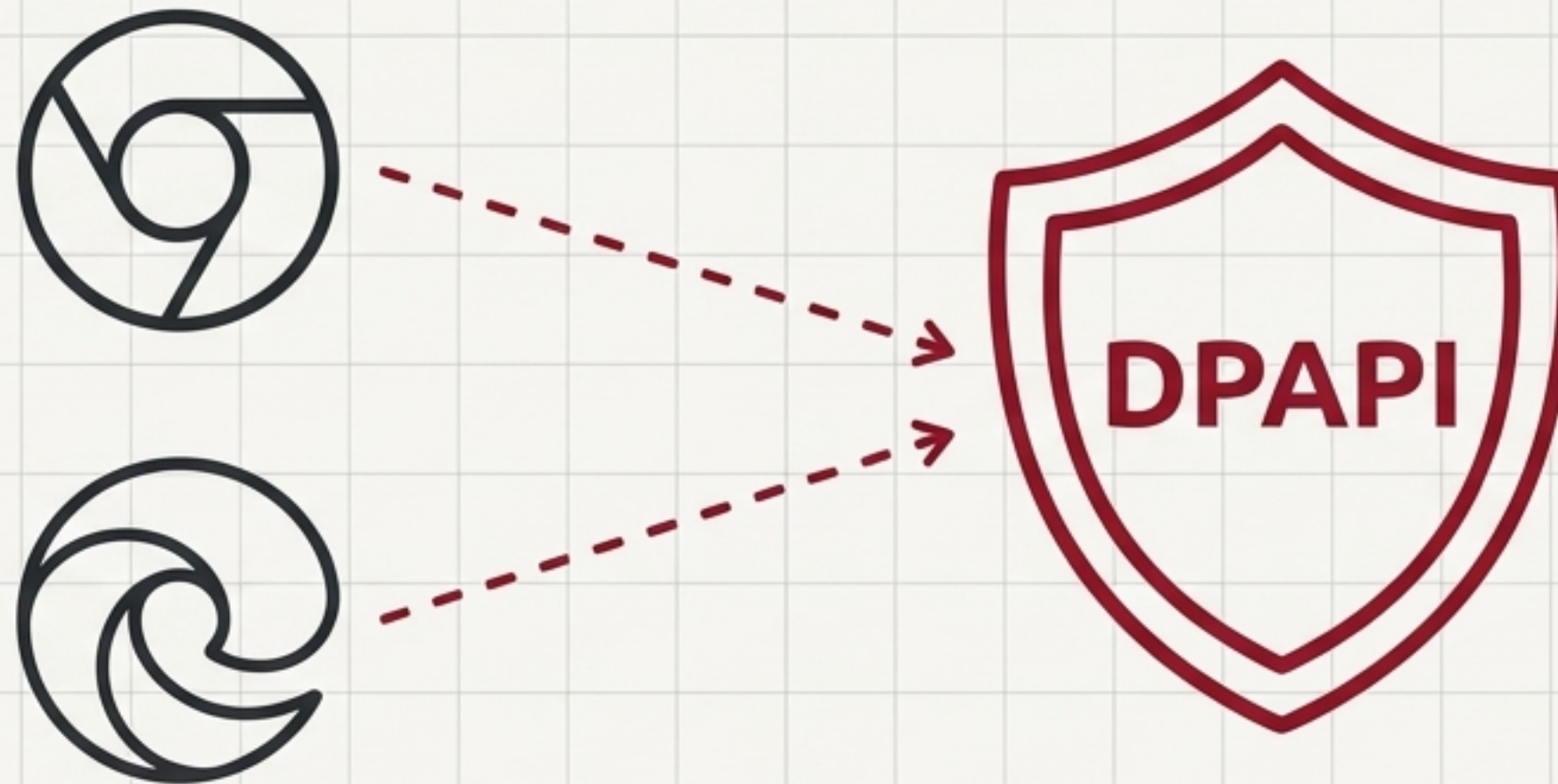
Aplicaciones como VNC o PuTTY pueden guardar información de sesión en el registro del usuario actual.

```
Get-ItemProperty  
"HKCU:\Software\TightVNC\Server"
```

```
Get-ItemProperty  
"HKCU:\Software\SimonTatham\PuTTY\  
Sessions"
```


Jugada 3 Explotando la Confianza: Credenciales del Navegador.

Los navegadores web son un tesoro de credenciales. Aunque están cifradas, un atacante con acceso al sistema puede intentar romper esa protección utilizando la Data Protection API (DPAPI) de Windows contra sí misma.



Descifrando Secretos con Mimikatz y DPAPI.

Herramientas como Mimikatz pueden utilizar las claves maestras de DPAPI del usuario para descifrar la base de datos de credenciales del navegador.

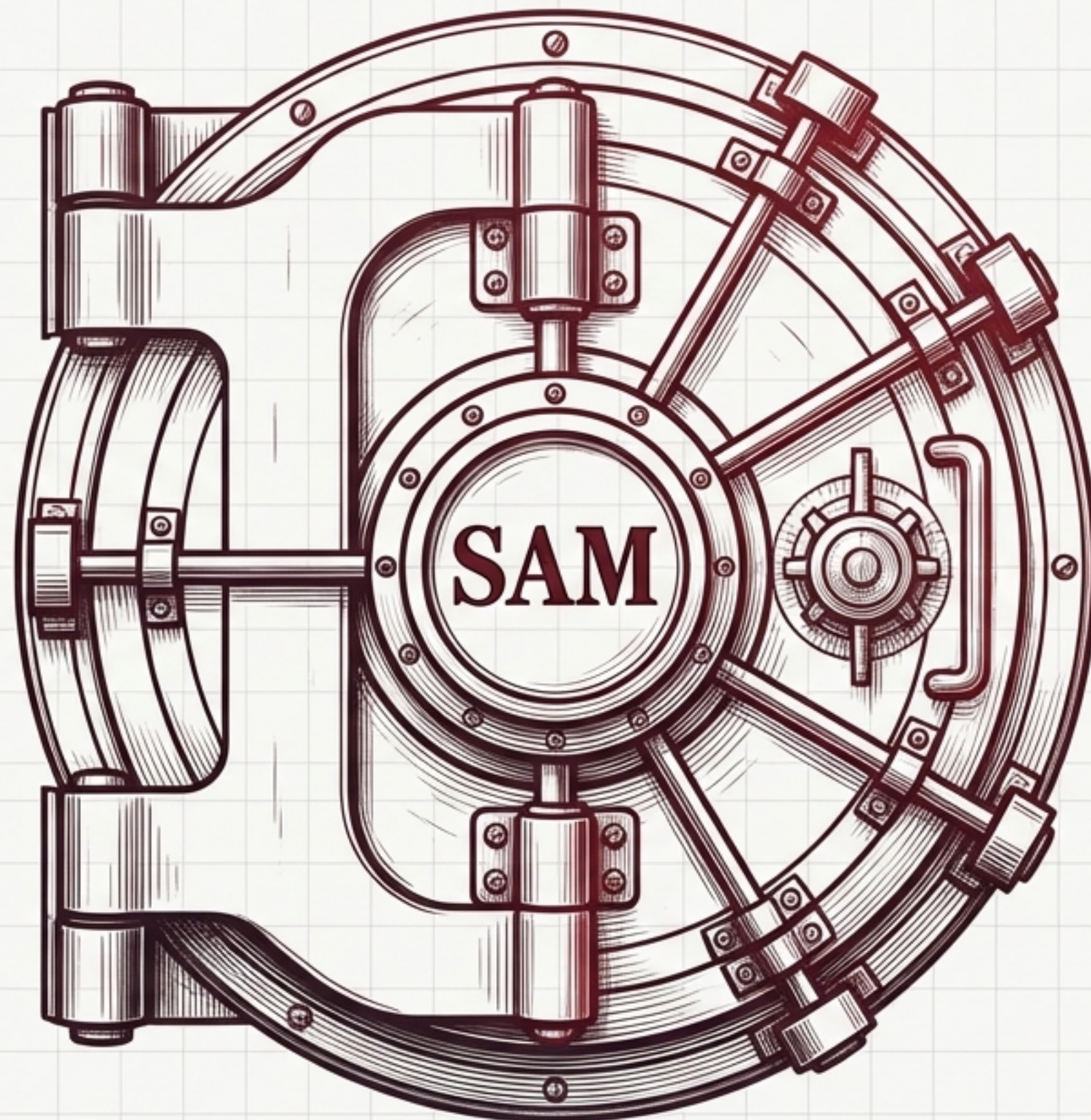
```
dpapi::chrome /in:"C:\Users\victim\AppData\Local\Google\Chrome\User  
Data\Default\Login Data" /masterkey: [MASTERKEY_HERE]
```

Explica que `[MASTERKEY\_HERE]` se obtiene previamente del sistema del usuario comprometido.

Jugada 4

Asalto a la Fortaleza: La Captura de Hashes NTLM.

El objetivo final para el control local son los hashes de contraseñas NTLM. Estos residen en la base de datos del Security Account Manager (SAM), un fichero altamente protegido por el sistema operativo.



¿Dónde Residen y Cómo se Obtienen los Hashes?

Un atacante no puede leer el fichero SAM directamente mientras el sistema está en ejecución. Sin embargo, a menudo puede acceder a él a través de copias de seguridad mal protegidas, 'shadow copies' (VSS) o ficheros de reparación.



C:\Windows\System32\config**SAM**



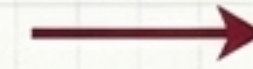
C:\Windows\System32\config\RegBack**SAM**



C:\Windows\repair**SAM**



LIVE SYSTEM
(LOCKED)



SHADOW COPY
(UNLOCKED - VSS)

Jugada 5

La Llave Maestra: Autenticación con Pass-the-Hash.

Con un hash NTLM válido, no es necesario 'crackearlo' para obtener la contraseña en texto plano. Es posible utilizar el hash directamente para autenticarse en otros sistemas de la red que usen el mismo usuario y contraseña, un ataque conocido como 'Pass-the-Hash'.



Ejecutando el Ataque con Evil-WinRM.

Herramientas como Evil-WinRM permiten a un atacante establecer una sesión remota de PowerShell (WinRM) contra un objetivo, autenticándose directamente con el nombre de usuario y su hash NTLM.

```
evil-winrm -u [USERNAME] -H [NTLM_HASH] -i [TARGET_IP]
```

Acceso total, sin conocer la contraseña original.

Cambiando el Juego: La Perspectiva del Defensor

“ 'Estos ejemplos no son 'trucos mágicos de hacker'; son errores de diseño y operación que vemos una y otra vez. ”

Nuestro Manual: Entender para Proteger.

Cuanto mejor entendamos cómo se roban contraseñas, sesiones y hashes, mejor podremos:



Detectar

Reconocer estos comportamientos anómalos en logs y alertas del sistema.



Explicar

Traducir el riesgo técnico en un impacto tangible para el negocio.



Priorizar

Enfocar los esfuerzos en las medidas de 'hardening' y respuesta a incidentes que realmente importan.